Standard Operating Procedure (SOP) for Risk Management

Objective

This SOP outlines the steps and procedures for managing risk requests within the ASPIA platform. The goal is to ensure that risks are handled efficiently, with proper approvals, and that the entire process is tracked and documented.

Scope

This procedure applies to all users involved in the submission, review, and approval of risk requests in the ASPIA platform.

Risk Request Workflow (Flow Description)

This section describes the complete end-to-end flow of a risk request, from submission to closure, as represented in the process flow chart.

1. **Initiator Submits Risk** — The initiator creates and submits a new risk request. At this point, the risk status is set to **"New"** and its state is **"Inactive."**
2. **Business Head Reviews the Risk Request** — The request moves to the Business Head for review. Three outcomes are possible:
3. **Require more info** → Status becomes **"Info Required"**, state remains **"Inactive."** The request goes back to the initiator for more details, after which it can be resubmitted into the review loop.
4. **Reject** → Status becomes **"Rejected"**, state becomes **"Inactive."** The risk is rejected by ASPIA and the flow ends (branches to "ASPIA reject the risk").
5. **Approve** → Status becomes **"Review"**, state remains **"Inactive."** The request proceeds to the next approval stage.
6. **ISG/CISO Approval** — The request is reviewed by the ISG/CISO. Three outcomes are possible:
7. **Require more info** → Status becomes **"Info Required"**, state remains **"Inactive."** Sent back into the initiator/review loop.
8. **Reject** → Status becomes **"Rejected"**, state becomes **"Inactive."** Flow ends at "ASPIA reject the risk."
9. **Approve** → Status becomes **"Monitor"**, state becomes **"Active."** The risk is now registered.
10. **Risk Registered** — Once approved by ISG/CISO, the risk is officially registered in the system and enters the monitoring/mitigation phase.
11. **Mitigation Owner Submits Mitigation** — The assigned Mitigation Owner works on the risk and decides whether to submit mitigation:
12. **No** → Status remains **"Monitor"**, state remains **"Active."** The risk stays as an **Active Risk** until mitigation is submitted.
13. **Yes (Partially or Fully)** → The mitigation submission moves forward to a date check.
14. **Before Planned Mitigation Date (Check)** — The system checks whether the mitigation was submitted before the planned mitigation date:
15. **No** → Status becomes **"Monitor – Overdue."** The risk is flagged as overdue and routed to the Approve/Reject decision.

16. **Yes** → Status remains **"Monitor – Active."** The risk proceeds normally to the Approve/Reject decision.
17. **Approve/Reject (Mitigation Approver Decision)** — The Mitigation Approver reviews the submitted mitigation:
18. **Rejected** → Status remains **"Monitor – Active."** The mitigation is sent back into the mitigation submission loop (mitigation owner resubmits).
19. **Partially Approved** → Status remains **"Monitor – Active."** The risk is treated as an Active Risk and continues to be tracked/mitigated further.
20. **Fully Resolved** → The request proceeds to the final CISO approval stage.
21. **CISO Approve/Reject (Final Mitigation Approval)** —
22. **Rejected** → Status remains **"Monitor – Active."** Sent back into the Approve/Reject mitigation loop.
23. **Approved** → Status becomes **"Closed"**, state becomes **"Inactive."** The risk moves to "Risk Closed" — the process ends successfully.

Summary of Status/State transitions across the flow: | Stage | Status | State | |---|---|---| | Risk submitted | New | Inactive | | Sent back for info (any stage) | Info Required | Inactive | | Approved by Business Head | Review | Inactive | | Rejected (Business Head or ISG/CISO) | Rejected | Inactive | | Approved by ISG/CISO | Monitor | Active | | Mitigation submitted before planned date | Monitor | Active | | Mitigation submitted after planned date | Monitor | Overdue | | Mitigation partially approved | Monitor | Active | | Mitigation fully approved by CISO | Closed | Inactive |

Risk Configurations

Approvers Configuration Screen (Description)

The **Risk Configuration** screen under **GRC Configurations** shows a dark-themed admin panel. The left-hand sidebar contains the main ASPIA navigation menu with items such as Dashboard, Status Board, Assets, Requests, Issues, Governance, Risk Management, Compliance, Assessments, Risk Advisory, Incident Response, Teams, Reports, Calendar, and a Settings section with Users below it. The top bar shows the ASPIA logo, a search field, and icon shortcuts (folder, settings gear, notification bell, trash/delete icon) along with a "Team" dropdown on the top right.

The main content area is titled **"GRC Configurations"** and has a horizontal tab bar with the following tabs: **Dynamic Values, Risk Configuration** (currently selected), **Catalog, Notification Setting, Exception, Vendor, Upload Frameworks, SCD Setting, Risk Advisory Setting.**

Within the Risk Configuration tab, there is a second-level tab bar containing: **Risk Approvers** (selected/highlighted in blue), **Risk Mitigation Approvers, Neutral Approver Configuration, Classic, Custom.**

Below these tabs is a table with two columns — **ID** and **Approvers** — plus an **Action** column, and a "+" (add) button in the top-right corner of the table to add a new approver entry. The table is currently empty (0 of 0 records), with pagination controls ("Items per page: 50") at the bottom.

1 - Risk Approvers

- **Navigation**: Go to **GRC Configuration > Risk Configuration > Risk Approvers**. Click on the **Add** button to add risk approvers. You can define multiple levels of approvers based on the requirements.
- **Usage**: Risk Approvers are involved in the **risk acceptance** process. Once a risk is created, it is routed **to the configured approvers, level by level,** for approval.

"Add Risk Configuration" pop-up (Description): A modal dialog titled **"Add Risk Configuration"** appears over the darkened background. It contains a repeatable set of approver-level blocks, each with two dropdown fields: - **Type*** — a dropdown to select the approver type (e.g., "Users" or "Teams"). - **Approvers*** — a dropdown to select the specific approver(s) for that type.

Each block has a red minus ("−") icon on the right to remove that level. In the example shown, three approval levels are configured: 1. Type: **Users** → Approver: **Will Hu (rajesh@aspiainfotech.com)** 2. Type: **Teams** → Approver: **ADS Operation** 3. Type: **Users** → Approver: **Nilesh Gade (shubh90@gmail.com)**

Below the levels there is a small "+" icon to add another approver level. At the bottom of the modal are two buttons: a blue **"Save"** button and a **"Cancel"** button.

2 - Risk Mitigation Approvers

- **Navigation**: Go to **GRC Configuration > Risk Configuration > Risk Mitigation Approvers**. Click on the **Add** button to define mitigation approvers. Multiple approval levels can be added as needed.
- **Usage**: Risk Mitigation Approvers are used during the **risk mitigation** phase. Once a risk is accepted and partially or fully mitigated, it is routed **to the configured approvers, level by level,** for approval.

"Edit Risk Review Configuration" pop-up (Description): A modal titled **"Edit Risk Review Configuration"** shows an "Add Approvals" section with repeatable Type/Approvers pairs, each removable via a red minus icon: 1. Type: **Users** → Approver: **Rohit Basera (mohit@aspiainfotech.com)** 2. Type: **Teams** → Approver: **Network Team**

A "+" icon below adds more levels. The modal has **"Update"** (blue button) and **"Cancel"** buttons at the bottom. The table behind the modal shows column headers and pagination ("Items per page: 50", showing "1–1 of 1").

3 - Risk Neutral Approver (Optional)

- **Navigation**: Go to **GRC Configuration > Risk Configuration > Neutral Approver Configuration**. Click on the **Add** button to set a neutral approver. Only one neutral approver can be added.
- **Usage**: A Risk Neutral Approver is used when the **risk owner and approver are the same person** at any approval level. In such cases, the approver at that level is replaced by the neutral approver.

"Add Neutral Approver Configuration" pop-up (Description): A compact modal titled **"Add Neutral Approver Configuration"** with two fields: - **Type*** — dropdown, set to **Users**. - **Approvers*** — dropdown, set to **Kamal Gunwant (kamal.gunwant@aspiainfotech.com)**.

At the bottom are **"Save"** (blue) and **"Cancel"** buttons.

Note: If the Neutral Approver is not configured and the **risk owner and approver are the same person** at any level, that level will be **automatically approved.**

Risk Formula Configurations

Usage: Risk Formulas are used to calculate the **Risk Score** based on various input parameters such as Impact, Likelihood, and Detectability. This score helps in categorizing the risk level (e.g., Low, Medium, High, Critical) and drives decision-making for mitigation and approvals.

Classic Formula

- The **Classic** formula uses a fixed mathematical equation, typically in the form: **Risk Score = Impact × Likelihood**

Classic Formula Screen (Description): Under the **Risk Configuration** tab, a **"Classic"** sub-tab is selected (next to a "Custom" sub-tab). This displays a risk-scoring matrix grid: - The top row shows four risk-band labels with editable ranges and colored indicators: **0.00–4.00 (Medium, yellow)**, **1.00–5.00 (Low, green)**, **10.00–15.00 (High, orange)**, **15.00–25.00 (Critical, red)** — each with edit (pencil) and delete (trash) icons, and a "+" to add another band. - The left column lists **Likelihood levels** (rows), from top to bottom: **5 – Almost Certain (Very High)**, **4 – Likely (High)**, **3 – Possible (Medium)**, **2 – Unlikely (Low)**, **1 – Rare (Very Low)** — each editable with pencil/trash icons. - The bottom row lists **Impact levels** (columns): **1 – Insignificant (Very Low)**, **2 – Minor (Low)**, **3 – Moderate (Medium)**, **4 – Major (High)**, **5 – Critical (Very High)**. - The grid cells contain the calculated numeric risk scores (Impact × Likelihood) for each Likelihood/Impact combination — values visible in the matrix range roughly from 1 up to 25, colored according to which risk band they fall into (green/yellow/orange/red), giving a visual heat-map style risk matrix.

Custom Formula

- The **Custom** formula allows organizations to define their own logic using available fields (e.g., Impact, Likelihood, Detectability, or any custom fields).

Custom Formula Screen (Description): The **"Custom"** sub-tab is selected. Similar to the Classic view, it shows a grid with band ranges across the top (e.g., **1.00–5.00 Low**, **6.00–10.00 Medium**, **11.00–15.00 High**, **16.00–20.00 Critical**) each with edit/delete icons and a "+" to add more bands.

Below that is a table listing custom fields with columns: **Image, Rule, Name, Critical, High, Medium, Low, Edit, Delete**. Rows shown include custom risk factors such as: - **Confidentiality Impact** - **Integrity Impact** - **Availability Impact** - **Probability of Occurrence**

Each row has numeric weight/score values under the Critical/High/Medium/Low columns, plus edit (pencil) and delete (trash) action icons.

At the bottom is a **"Risk Formula"** section header showing the formula expression being built (e.g., "*Confidentiality Impact + Integrity Impact + Availability Impact + Probability of Occurrence*"), followed by rows of **"Phrase Operand/Operator"** dropdown fields — each with a numeric/operand dropdown, a red minus icon to remove that term, and additional similarly structured rows for combining the custom fields (Confidentiality Impact, Integrity Impact, Availability Impact, Probability of Occurrence) using operators, allowing the organization to build a custom scoring formula piece by piece.

Dynamic Column Configuration

- **Navigation:** Go to **GRC Configuration > Dynamic Values > Dynamic Form**. Click on the **Add** button to create dynamic columns.
- **Usage:** Dynamic columns can be created based on organization requirements. If a user needs to add a custom field in the risk form that is not available by default, they can easily create it using this feature.

"Create Custom Form" pop-up (Description): A modal titled **"Create Custom Form"** appears over a background list of existing dynamic fields (rows with a three-dot action menu on the right, numbered items 1 through roughly 8, showing "1–8 of 8"). The modal contains: - **Module*** — dropdown set to **Risk Management**. - An **"Add Field"** section with: - **Field Name*** — text input, example value **"Dynamic Risk Column."** - **Required*** — dropdown set to **False**. - **Field Type*** — dropdown set to **Input** (with a red minus icon to remove this field definition). - **Multiple*** — dropdown set to **False**. - **Add Options** — a "+" button to add selectable option values (used when Field Type is a dropdown/multi-select type rather than plain input). - A "+" icon below to add another custom field within the same form. - Bottom buttons: **"Save"** (blue) and **"Cancel."**

Label Customization

- **Navigation:** Go to **GRC Configuration > Dynamic Values > Label**. Click on the **Risk Management** to get all risk labels listing.
- **Usage**: You can **edit the display names** of columns or **hide specific fields** and also change the ordering and size of the column from the risk form as needed.

Label Listing Screen (Description): Under **GRC Configurations**, the tab bar shows **Dynamic Values** (selected), Risk Configuration, Catalog, Notification Setting, Exception, Vendor, Upload Frameworks, SCD Setting, Risk Advisory Setting. A second-level tab bar shows **Custom Form** and **Label** (selected, highlighted blue). The table below has columns: **ID, Module, Action** (with numbered rows 1 through 7 visible, showing module names in blue links such as "Risk Management," "Risk Mitigation," "Risk Review," "Vendor Exception," "Vendor Documents," "Additional Location," "Additional Question"), each with a three-dot action menu, and pagination showing "1–11 of 11."

"Edit Label Form" pop-up (Description): A modal titled **"Edit Label Form"** with the following fields: - **For Form** — text input showing **"Risk Management."** - **Label** — text input showing **"Frameworks."** - **Key** — text input (appears blank/placeholder in this view). - **Hide** — dropdown set to **No.** - **Ordering** — numeric input

showing **33.** - **ClassName** — text input showing **"col-4."** - Bottom buttons: **"Update"** (blue) and **"Cancel."**

Behind the modal, the underlying table (also titled around "Risk Management") shows columns: **ID, Name, For, Key, Hide, Ordering, Class Name, Action**, listing multiple label rows each with a value of "risk_management" under "For," various keys like "field_id," and "col-4" repeated under Class Name, each row having a three-dot action menu.

Notification Setting

Before Notification Setting

- **Navigation:** Go to **GRC Configuration > Notification Setting > Risk Management**. Click on the add button to add the notification setting.
- **Usage**: **Before notifications** are sent out based on the **Planned Date** of the risk. You can configure multiple notifications to be triggered at specific intervals **before** the planned date to alert relevant users in advance.

After Notification Setting

- **Navigation:** Go to **GRC Configuration > Notification Setting > Risk Management**. Click on the add button to add the notification setting.
- **Usage**: "After" notifications are sent **following the Planned Date** of a risk-related event. You can configure **multiple notifications** to be triggered at specific intervals after the planned date to keep relevant users informed and ensure timely follow-ups.

Notification Setting Listing Screen (Description): Under **GRC Configurations**, the top tab bar shows Dynamic Values, Risk Configuration, Catalog, **Notification Setting** (selected), Exception, Vendor, Upload Frameworks, SCD Setting, Risk Advisory Setting. A second-level tab bar lists: Exceptions, Audit Collection, Audit Observation, **Risk Management** (selected/highlighted), Document Program, Risk Advisory, Vendor Tier, Vendor Contract.

The table below shows columns: **ID, Name, Days, User, Action**. Two example rows are shown: 1. **"Before 1 Day Notification"** — Days: **1** — User column shows an **"Attach"** button. 2. **"After 1 Day Notification"** — Days: **1** — User column shows an **"Attach"** button.

Each row has a three-dot action menu, and pagination shows "1–2 of 2." A "+" (add) button appears at the top right of the table to create a new notification rule.

"Edit Mitigation Plan" pop-up (Description): A modal (used when editing a notification rule) with the following fields: - **Name*** — text input showing **"After 1 Day Notification."** - **Notification Type*** — dropdown showing **"After Due Date."** - **Days*** — numeric input showing **1.** - **User** — dropdown/multi-select showing **"Nilesh Gade (shubh90@gmail.com)."** - Bottom buttons: **"Save"** (blue) and **"Cancel."**

Manager Level Escalation

Navigation

Go to **GRC Configuration > Notification Setting > Risk Management** and select any notification rule (Before or After). While configuring the notification, you can set the **Manager Levels** value.

Usage

Manager Level Escalation enables the system to automatically forward notifications to the supervisory hierarchy above the responsible user. This ensures visibility, accountability, and timely follow-up on risk activities.

Depending on the value set in **Manager Levels**, notifications will be escalated to: - **Level 1** → Sends notification to the user's **direct manager** - **Level 2** → Sends notification to the **manager** and the **manager's manager** - **Level 3+** → Escalates further up the chain, sending notifications to the next-level managers for the specified

number of levels

This ensures that not only the responsible user but also their supervisory chain is informed about risk deadlines, breaches, or required follow-ups.

"Add Risk Management" (Notification) pop-up (Description): A modal titled **"Add Risk Management"** within GRC Configurations, showing the second-level tab bar (Exceptions, Audit Collection, Notification Setting, Exception, Vendor, Upload Frameworks, SCD Setting, Risk Advisory Setting) behind it. The modal fields are: - **Name*** — text input showing **"After 1 days."** - **Notification Type*** — dropdown showing **"After Next Date."** - **No Of Days*** — numeric input showing **1.** - **User** — dropdown showing **"User 1 (user1@aspiainfo.in)."** - **Number of Levels** — a repeatable list, showing two escalation-level entries: **"1 Escalation Level"** and **"2 Escalation Level,"** each with a red minus icon to remove it, plus a "+" icon below to add more escalation levels. - Bottom buttons: **"Save"** (blue) and **"Cancel."**

Workflow Overview

Initiator Submits a Risk Request

Step 1: Access the ASPIA Platform

- **Action**: Log in to the ASPIA platform using your credentials.
- **Navigation**: Go to the "Risk Management" module from the menu.

Risk Management Listing Screen (Description): The main ASPIA interface with the left sidebar showing the full navigation menu (Dashboard, Status Board, Assets, Requests, Issues, Governance, **Risk Management** — expanded, showing sub-items **Dashboard** and **Listing** — Compliance, Assessments, Incident Response, Teams, Reports, Calendar, Settings/Users). The main panel is titled **"Risk Management"** with a table showing columns: **ID, Subject, Status, Inherent Risk, External Ref ID, Control Number, Risk Assessment, Affected Assets, Action**. One example row is visible: Subject "Risk Management," Status shown as a **red "New" badge**, Inherent Risk value "5." A red "+" (add) button, a filter icon, a settings icon, and a search box appear in the top-right of the table header. Pagination shows "1–1 of 1."

Step 2: Initiate a New Risk Request

- **Action**: Click on the "Add Risk" button.
- **Form Completion**:
- **Subject**: Provide the name of the risk.
- **Additional Notes**: Provide a detailed description of the risk you are requesting.
- **Attachments**: Upload any supporting documents if required.

"Add Risk" Form Screen (Description): A detailed risk-creation form titled **"Add Risk"** with fields arranged in a two-column layout: - **Subject*** — text input, prefilled "Risk Management." - **Risk Mapping** — dropdown, showing "Inability to maintain individual accountability." - **Threat Mapping** — dropdown (multi-select style). - **Category** — dropdown. - **Risk Source** — dropdown. - **Site/Location** — dropdown. - **Risk Score Method** — dropdown, set to "Classic." - **Current Impact** — dropdown, showing "4 – Likely (High)." - **Current Likelihood** — dropdown, showing "3 – Moderate (Medium)." - **Internal Ref ID** — text input. - **Control Number** — text input. - **Frameworks** — dropdown. - **Assets** — dropdown. - **Technology** — dropdown. - **Teams** — dropdown. - **Additional Stakeholder** — dropdown. - **Risk Assessment** — dropdown. - **Additional Notes** — text area. - **Owner*** — dropdown, showing "Kamal Gunwant (kamal.gunwant@aspiainfotech.com)." - **Tags** — dropdown. - **Supporting Documents** — file upload control ("Choose File," "No file chosen"). - **Contact** — text input. - **Existing Control** — dropdown. - **Mitigation Owner** — dropdown, showing "Kamal Gunwant (kamal.gunwant@aspiainfotech.com)." - **Planned Closure Date*** — date picker, showing "06/30/2026." - **Planning Strategy** — dropdown.

On the far right of the screen is a small side panel labeled **"Risk Assess Action."** Bottom of the form has **"Save"** (blue) and **"Cancel"** buttons.

Step 3: Submit the Risk Request

- **Action**: After completing the form, click on the "Save" button.
- **Status**: The request is now in the "New" status.
- **State**: The request is "Inactive" until it is reviewed.
- **Notification**: ASPIA sends an automated email notification to the Risk Owner and the first approver.

Business Head Reviews the Request

Step 1: Receive Notification

- **Action**: First approver (business head) receives an email notification with details of the submitted risk request.

Step 2: Access the Request in ASPIA

- **Action**: Log in to ASPIA and navigate to the "Risk Management" module.
- **Navigation**: Open the risk request.

Step 3: Review the Risk Request

- **Action**: Review the details provided by the initiator, including the necessary details and any attached documents.

Step 4: Make a Decision

Decision Options:

Approve: - **Action**: Click "Approve" to move the request to the next stage. - **Status**: The request status changes to "Review." - **State**: The request remains "Inactive." - **Notification**: An email is sent to the Risk Owner and Second Approver (configured from configuration).

Risk Detail Review Screen — Approve state (Description): The risk record detail page, opened from the "Risk Management" module, with three tabs at the top: **Risk Detail** (selected/highlighted blue), **Mitigation**, **Review**. In the top-right corner of the page there is a small action toolbar showing a **checkmark icon highlighted in a pink/magenta box** — representing the **Approve** action button. Below the tabs, summary widgets display: **Inherent Risk** (value "5"), **Residual Risk** (value "5"), a **Risk Scoring** panel showing "High (3)" with sub-labels "Impact" and "Likelihood (4)," and a **Risk Owner** panel showing the assigned owner's name in a green badge. Below that is the same detailed form layout as the "Add Risk" screen (Subject, Risk Mapping, Threat Mapping, Category, Risk Source, Site/Location, Risk Score Method, Current Impact, Current Likelihood, Internal Ref ID, Frameworks, Assets, Technology, Teams, Additional Stakeholder, Risk Assessment, Additional Notes, Risk Owner, Contact, Tags, Existing Control, Supporting Documents), all populated with the submitted values and mostly in a read/review mode.

Reject: - **Action**: Click "Reject" to deny the risk request. - **Status**: The request status changes to "Closed." - **State**: The request becomes "Inactive." - **Notification**: An email is sent to the Risk Owner, informing them of the rejection.

Risk Detail Review Screen — Reject state (Description): The same Risk Detail page layout as above, but the top-right action toolbar now highlights a **trash/delete (reject) icon in a pink/magenta box**, representing the **Reject** action. The rest of the layout (Inherent Risk, Residual Risk, Risk Scoring, Risk Owner panels, and the full detail form fields) is identical in structure to the Approve-state screen, just shown in the context of choosing to reject.

Send Back: - **Action**: Click "Send Back" to request additional information from the initiator. - **Status**: The request status changes to "Info Required." - **State**: The request remains "Inactive." - **Notification**: An email is sent to the Risk Owner, requesting further details.

ISG/CISO Reviews the Risk Request

Step 1: Receive Notification

- **Action**: Second Approver (ISG/CISO) receives an email notification for approval.

Step 2: Access the Request in ASPIA

- **Action**: Log in to ASPIA and navigate to the "Risk Management" module.
- **Navigation**: Open the risk request from the "Pending Approvals" section.

Step 3: Review the Risk Request

- **Action**: Review the comments and any additional information provided by the initiator or first approver.

Step 4: Make a Decision

Decision Options:

Approve: - **Action**: Click "Approve" to move the request to the final approver. - **Status**: The request status changes to "Monitor." - **State**: The request becomes "Active." - **Notification**: An email is sent to the Risk Owner, informing them that the risk has been approved.

Risk Detail Screen — ISG/CISO stage (Description): Same three-tab layout (Risk Detail, Mitigation, Review) with a top-right action toolbar showing a **downward chevron/dropdown icon highlighted in a pink/magenta box** (representing the decision menu for Approve/Reject/Send Back at this stage). The summary widgets again show Inherent Risk and Residual Risk values, a Risk Scoring panel ("High," with Impact/Likelihood sub-values), and a Risk Owner badge. The status field within the form now shows **"Closed"** (in this particular captured example) as the Risk Score Method context, illustrating how the status field updates as the risk progresses through stages.

Reject: - **Action**: Click "Reject" to deny the risk request. - **Status**: The request status changes to "Closed." - **State**: The request becomes "Inactive." - **Notification**: An email is sent to the Risk Owner, informing them of the rejection.

Send Back: - **Action**: Click "Send Back" to request additional information from the initiator. - **Status**: The request status changes to "Info Required." - **State**: The request remains "Inactive." - **Notification**: An email is sent to the Risk Owner, requesting further details.

Send Back Process

- If a risk is sent back at any stage of the approval workflow, it is **sent back to the Risk Owner** for modifications.
- The **approver** will specify the reason for sending the risk back (e.g., missing information, inadequate mitigation plan).

Risk Owner Modifications

- Once the risk is sent back, the **Risk Owner** is notified and must take the following actions:
- Review the feedback provided by the approver.
- Make the necessary modifications to the risk, such as:
  - Updating risk details (e.g., subject, description).
  - Revising the mitigation plan.
  - Addressing any concerns raised by the approver.
- After making the modifications, the Risk Owner will re-submit the risk for approval by selecting the **Submit for Re-Approval** option.

Risk Detail Screen — Resubmission state (Description): The same three-tab Risk Detail layout, with the top-right toolbar now showing a **save icon and a paper-airplane/"send" icon**, both highlighted, representing the **Save** and **Submit for Re-Approval** actions available to the Risk Owner after making edits. The rest of the form (Subject, Risk Mapping, Threat Mapping, Category, Risk Source, Current Impact, Current Likelihood, Internal Ref ID, Assets, Technology, Additional Stakeholder, Risk Owner, Contact, Risk Assessment, Tags, Existing Control,

Additional Notes, Supporting Documents) is shown in an editable state.

Adding Mitigation Details

- **Once the risk is fully approved**, the **Risk Owner** is responsible for adding the necessary details in the **Mitigation Section**:
- **Mitigation Owner**: Assign the individual responsible for implementing the mitigation actions.
- **Mitigation Approver**: Specify the approver who will review and approve the mitigation plan once it is completed.
- **Planned Mitigation Date**: Enter the expected completion date for the mitigation plan.
- Any other relevant mitigation details must be added to ensure the risk is adequately managed.

Mitigation Tab Screen (Description): The risk detail page with the **"Mitigation"** tab now selected (highlighted blue) among the three tabs (Risk Detail, Mitigation, Review). Summary widgets at the top show: **Severity** (a red badge), **Status** (a green badge), **Inherent Risk** and **Residual Risk** numeric values, a **Risk Scoring** panel (showing Likelihood/Impact sub-values, e.g., "Unlikely (Low)" and "Minor (Low)"), and a **Risk Owner** badge showing the assigned owner in green.

Below the widgets, the mitigation form fields are laid out as: - **Submission Date** — date field. - **Planned Date*** — date field. - **Planning Strategy** — dropdown. - **Mitigation Effort** — dropdown. - **Mitigation Cost** — input field. - **Mitigation Percent** — input field. - **Teams** — dropdown, showing "ADS Info Sec." - **Mitigation Owner*** — dropdown, showing "Kamal Gunwant (kamal.gunwant@aspiainfotech.com)." - **Current Solution** — text area. - **Security Requirements** — text area. - **Security Recommendations** — text area. - **Supporting Documents** — file upload control ("Choose File," "No file chosen"). - **Controls** — dropdown/multi-select. - **Risk Score Method** — dropdown, set to "Classic." - **Current Impact** — dropdown. - **Current Likelihood** — dropdown, showing "3 – Minor (Low)."

A save icon and a "send/submit" (paper-airplane) icon appear in the top-right toolbar for saving and submitting the mitigation form.

Submit the Risk Mitigation

- **Action**: After completing the form, click on the "Save" button.
- **Notification**: ASPIA sends an automated email notification to the Risk Mitigation Owner and Risk Mitigation Approver.

Mitigation Process

1. Mitigation by Mitigation Owner

- The **Mitigation Owner** is responsible for carrying out the mitigation actions. Once the mitigation actions are complete, the Mitigation Owner fills out the **Likelihood** and **Impact** fields related to the risk.
- After completing these details, the Mitigation Owner submits the mitigation for approval.

2. Send for Approval

- Once submitted, an email notification is sent to the **Mitigation Approver** for review and approval.

Mitigation Tab — Extended Example Screen (Description): A second example of the Mitigation tab, for a risk titled at the top of the page (a long subject line referencing a cyber-attack/breach scenario causing business disruption, financial loss, data leakage, reputational damage, regulatory liability, third-party claims, and people-safety risk due to cyber attack — shown as a banner/title at the top of the screen). Below it, the same three tabs appear (Risk Detail, Mitigation — selected, Review), with summary widgets: **Severity** (red badge, "High"), **Status** (green badge, "Active"), **Inherent Risk** and **Residual Risk** values, a **Risk Scoring** panel showing "3 – Possible (Medium)" and "3 – Critical (Very High)" for Likelihood/Impact, and a **Risk Owner** badge.

Form fields shown: **Submission Date, Planned Date*, Planning Strategy** (dropdown, "Mitigate"), **Mitigation**

Effort (dropdown, "Considerable"), **Mitigation Percent** (numeric, "75"), **Teams** (multi-select, "ADS Info Sec"), **Current Solution** (text area), **Mitigation Owner*** (dropdown, "Jacob Mcclure (jsawyer@amerihost.com)"), **Security Requirements** (text area), **Security Recommendations** (text area), **Supporting Documents** (file upload), **Controls** (multi-select showing two selected values: "Steering Committee & Program Oversight" and "Publishing Cybersecurity & Data Protection Documentation"), **Risk Score Method** (dropdown, "Classic"), **Current Impact** (dropdown, "3 – Possible (Medium)"), **Current Likelihood** (dropdown, "5 – Critical (Very High)"). Below the visible fields is a section header **"Controls Details."**

Decision Options for Mitigation Approver

1. If Mitigation Percentage is Less than 100%

Send for the Approval only to the first mitigation approver

Approved by Mitigation Approver: - **Action**: Click "Approve." - **Residual Risk**: Residual risk will be calculated as per the configured risk formula and displayed on the screen. - **Notification**: An email is sent to the Risk Mitigation Owner.

Rejected by Mitigation Approver: - **Action**: Click "Reject." - **Residual Risk**: Residual risk will not be recalculated and will remain the same as earlier. - **Notification**: An email is sent to the Risk Mitigation Owner.

Review Tab Screen (Description): The risk detail page with the **"Review"** tab selected (highlighted blue), showing the same top summary widgets as before: **Severity, Status** (blue "Active" badge in this example), **Inherent Risk, Residual Risk, Risk Scoring** (Likelihood/Impact sub-values), and **Risk Owner** badge. Below is a **"Reviewer"** section with two fields: **Reviewer** (dropdown, currently blank/placeholder) and **Reviewer Date** (date field, placeholder "mm/dd/yyyy"), used for the Mitigation Approver to record their review action and date.

2. If Mitigation Percentage is 100%

Send for the Approval to all the mitigation approvers level by level

Approval Process:

Step 1: Approval by Mitigation Approver - Once the mitigation percentage reaches 100%, the mitigation is sent to the Mitigation Approver for review. - The Mitigation Approver reviews the provided mitigation and can either approve or reject it.

Approve by Mitigation Approver: - **Action**: Click **Approve** to approve the mitigation plan. - **Next Step**: Once approved, the mitigation plan is sent to the next approver (if one is configured) for further review and approval.

Reject by Mitigation Approver: - **Action**: Click **Reject** if the mitigation plan requires further modifications. - **Residual Risk**: If rejected, the Residual Risk will not be calculated. - **Notification**: An email is sent to the Risk Mitigation Owner, informing them that the mitigation was rejected.

Step 2: Approval by Final Mitigation Approver - Once the Mitigation Approver has approved the 100% mitigation, it goes to the Final Approver/CISO for final approval.

Approve by Final Approver: - **Action**: Click **Approve** to give final approval for the mitigation plan. - **Residual Risk**: The Residual Risk is automatically calculated and the Residual Risk score will become zero. - **Notification**: An email is sent to the Risk Mitigation Owner, notifying them that the risk has been fully mitigated and closed. - **Risk Status**: Closed.

Reject by Final Approver: - **Action**: Click **Reject** if the mitigation plan is unsatisfactory. - **Residual Risk**: If rejected, the Residual Risk will **not be calculated**. - **Notification**: An email is sent to the Risk Mitigation Owner, informing them of the rejection.

Change Approver

Privileged User Action

- **Action**: A user with higher privileges can change the approvers if any approver is unavailable, if the risk is not approved till now.

Dashboard for Risk Management

- **Navigation**: Go to **Risk Management > Dashboard** to view comprehensive visual insights related to Risk Management.
- **Usage**: The Central Dashboard is a comprehensive, real-time interface that provides actionable visual insights into your organization's risk landscape. Designed for clarity and efficiency, it consolidates risk-related data from across the system into a unified view, enabling faster analysis and informed decision-making.

Risk Management Dashboard Screen (Description): A dashboard view divided into a grid of widgets: - **Top-left widget**: A **donut/ring chart** (colored in green, orange, and red segments) representing risk distribution, with a small legend of colored icons/labels beside it (likely representing risk severity categories such as Low/Medium/High/Critical counts). - **Top-right widget**: A second **donut/ring chart** (blue-toned) with its own legend, likely representing a different breakdown (e.g., risk status distribution — New/Active/Closed, etc.). - **Middle-left widget**: A **bar chart** titled along the lines of "Risk Count by Category," showing three vertical bars of varying heights (in blue/teal/green tones) across category labels on the x-axis (e.g., categories such as "Product," "Asset Management," etc.). - **Middle-right widget**: A **bar chart** titled along the lines of "Risk Count by Owner," showing several vertical bars (in yellow, red, green, blue tones) of varying heights across owner names on the x-axis. - **Bottom widget**: A **horizontal stacked bar** titled something like "Risk Management Planned Vs Actual Dates," shown as a long horizontal bar divided into colored segments (orange/red on the left transitioning to green on the right), with a data table or legend below it listing dates/values in rows.

Filters in the Risk Management Module

Access the Risk Management Dashboard

On the right-hand side of the screen, you'll see a **filter panel** with multiple dropdowns and date selection fields. Click on the **filter icon** (located in the top toolbar of the Risk Management listing page, next to the add and settings icons) to open this panel.

Risk Listing with Filter Icon Highlighted (Description): The Risk Management listing screen (table with columns ID, Subject, Status, Inherent Risk, External Ref ID, Control Number, Risk Assessment) with a **filter (funnel) icon highlighted in a pink/magenta box** in the top-right toolbar, next to a "+" add button and a settings gear icon. Three example rows are visible in the table: "Risk Management" (green "Closed" badge), "Test" (purple "Rejected" badge, with a "New project" action tag), and "Risk Testing 24k" (blue "Monitor" badge, with a "Test Application" action tag).

Apply and Save Filters

Once you've selected the desired criteria, click the **"Apply"** button to update the list of risks shown on the dashboard based on the applied filters.

Filter Panel Open Screen (Description): The same Risk Management listing screen, but now with the **filter side-panel expanded on the right**, showing a **"Filter"** header with a save (disk) icon, a checkmark/apply icon, a reset icon, and a close ("X") icon at the top of the panel. Below that, a vertical stack of filter dropdown fields is listed: **Status, Mitigation Planned, Management Review, Assets, Severity, Owner, Added From, Team, Start Date** (date field, placeholder mm/dd/yyyy), **End Date** (date field, placeholder mm/dd/yyyy), **Category, Days From, Days To.**

To save the filter configuration for future use, click on the **Save icon**. This will allow you to name and store the filter settings, making it easy to reuse them later.

Filter Panel — Save Icon Highlighted (Description): The same expanded filter panel as above, but now the **save (disk) icon at the top of the panel is highlighted in a pink/magenta box**, drawing attention to the

action of saving the current filter configuration as a reusable named filter. The underlying risk table (with the same three example rows: "Risk Management" – Closed, "Test" – Rejected, "Risk Testing 24k" – Monitor) remains visible behind the panel.

If you want to reset the filters and see all risks again, click the **reset button** then save changes.

Filter Panel — Reset Icon Highlighted (Description): The same expanded filter panel layout, but now the **reset (circular arrow) icon at the top of the panel is highlighted in a pink/magenta box**, indicating the action to clear all currently applied filter values and restore the full, unfiltered risk list. All the same filter fields (Status, Mitigation Planned, Management Review, Assets, Severity, Owner, Added From, Team, Start Date, End Date, Category, Days From, Days To) remain visible in the panel.

Import Data

- **Step 1**: Go to the Risk Management section and locate the **Import** button at the top of the risk listing page.
- **Step 2**: Click the **Import** button to upload a file containing the risk data you want to import. Accepted formats are typically **.xlsx**.
- **Step 3**: A file selection dialog will appear; choose your file and upload it.

Risk Listing — Import/Export Icon Highlighted (Description): The Risk Management listing table (columns: ID, Subject, Status, Inherent Risk, External Ref ID, Control Number, Risk Assessment, Affected Assets, Action), with three example rows: "Risk Management" (green "Closed"), "Risk" (purple "Rejected," with "new project" tag), "Risk Testing 24k" (blue "Monitor," with "Test Application" tag). In the top-right toolbar, an **import/upload icon is highlighted in a pink/magenta box**, positioned among the other toolbar icons (add "+", filter, settings, search).

Important Notes

- Ensure that your file follows the required format (e.g., column headers match system fields).
- Review the data for any inconsistencies before uploading.

Export Data

- **Step 1**: To export risk data, select the risk(s) using the row checkboxes.
- **Step 2**: Click the **Export** button to download the current list of risks or filtered risks.
- **Step 3**: The system will generate the file, and it will be automatically downloaded to your device.

Risk Listing — Export Screen (Description): The same Risk Management listing table, now showing **checkboxes selected** on all three visible rows ("Risk Management," "Risk," "Risk Testing 24k"), with a header indicator reading **"3 items selected."** In the top-right toolbar, an **export icon is highlighted in a pink/magenta box**, next to a small numbered badge/counter reflecting the number of selected items, indicating the action of exporting the currently selected risk records.

Automated Email Notifications

Step 1: Due Date Reminder

- **Action**: As the risk's due date approaches, ASPIA triggers an automated email reminder to the Risk Owner.
- **Purpose**: To ensure that the Risk Owner is aware of the upcoming deadline and can take necessary actions if needed.

Activity Tracking

Step 1: Access the Risk's Activity Log

- **Action**: To view the history of actions taken on a specific risk request, log in to the ASPIA platform.
- **Navigation**: Go to the "Risk Management" module and select the relevant risk request.
- **Accessing the Log**: Click on the "Activity" tab within the risk request to view the log.
- **Details Available**: The activity log will show a chronological record of all changes, including submissions, approvals, rejections, and any modifications made to the request.

Step 2: Review the Detailed Activities

- **Action**: In the activity log, users can see detailed information about each action taken, such as:
- **Timestamp**: When the action was performed.
- **User**: Who performed the action.
- **Action Description**: What specific action was taken (e.g., "Risk Approval Date has been modified," "Risk Status has been modified").
- **Purpose**: This log allows users to track the progress of the risk request and provides transparency in the decision-making process.

Record Keeping

All risk requests and their corresponding actions, decisions, and notifications will be logged within the ASPIA platform for auditing and review purposes.